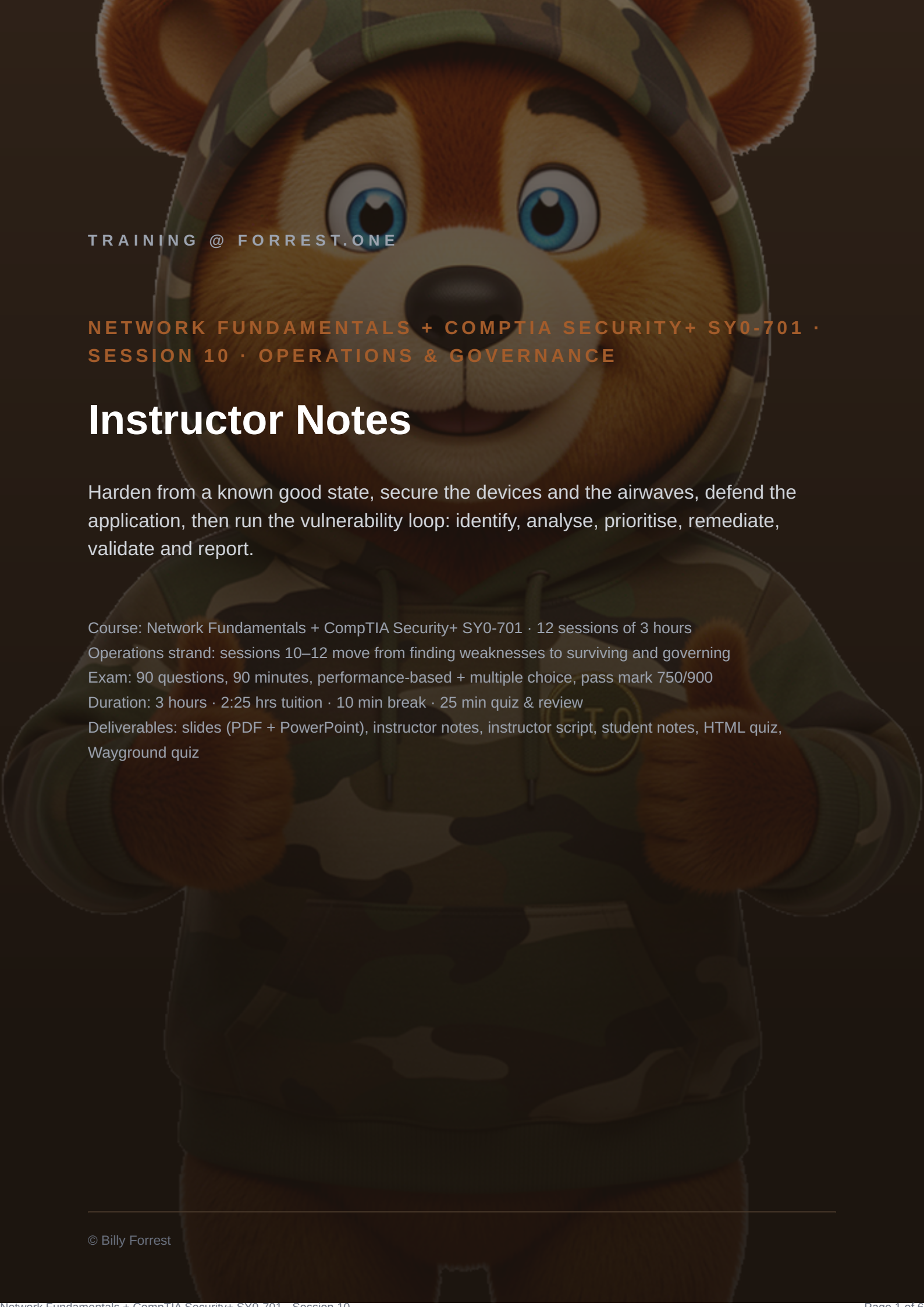




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 10 · OPERATIONS & GOVERNANCE

Instructor Notes

Harden from a known good state, secure the devices and the airwaves, defend the application, then run the vulnerability loop: identify, analyse, prioritise, remediate, validate and report.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

Operations strand: sessions 10–12 move from finding weaknesses to surviving and governing

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Instructor Notes: Vulnerability Management, Resiliency & Asset Protection

A 3-hour delivery guide for Session 10, aligned to the expanded six-chapter narration. Chapter 1 sets the known good state; chapter 2 secures the devices that leave and the air inside; chapter 3 hardens the application and starts the watching; chapter 4 accounts for the assets; chapter 5 is the heart of the session, the vulnerability loop; chapter 6 supplies the tooling. Keep one thread visible throughout: you cannot protect what you have not hardened, and you cannot fix what you cannot find.

Session at a glance

Time	Block	Slides	Focus / activity
0:00–0:15	Welcome and objectives	1–3	The six chapters; outcomes
0:15–0:40	Baselines and hardening	4–10	Baselines, drift, tooling; hardening at three layers
0:40–1:05	Mobile and wireless	11–15	Mobile risk, ownership models, WPA generations, rogue APs
1:05–1:15	Break	16	Ten minutes
1:15–1:35	Applications and monitoring	17–22	Secure coding, defences, what to watch, alerting
1:35–1:50	The asset lifecycle	23–28	Acquisition, assignment, tracking, disposal
1:50–2:15	Vulnerability management	29–36	Scan, score, prioritise, remediate, validate, report
2:15–2:25	Monitoring tooling	37–39	SIEM, behaviour analytics, dashboards, tuning
2:25–2:50	Quiz and review	40	Quiz_Session_10.html
2:50–3:00	Close	41–43	Takeaways; checklist; preview

Materials and preparation

- Projector or screen with the Session 10 slide deck (02_Slides.pdf or 02_Slides.pptx).
- One computer or tablet per pair for Quiz_Session_10.html (any browser, no internet required).
- Printed or digital copy of the Student Notes for each candidate.
- Whiteboard for the hardening layers diagram and the prioritisation grid.
- Optional: a sample vulnerability scan report, and a Centre for Internet Security Benchmark page to show a real baseline.

Delivery guidance by slide

Slides 1–3 · Welcome (15 minutes)

Walk the six chapters on slide 2 so candidates know where the session is going, then set the thread: a baseline makes normal definable, hardening removes entry points, and the loop turns findings into fixes. Slide 3 lists the outcomes; the quiz samples all of them.

Slides 4–10 · Baselines and hardening (25 minutes)

Slide 5 defines the baseline and names configuration drift as the enemy. Slide 6 gives the four steps: identify requirements, develop the configuration, test in a controlled environment, deploy and monitor. Slide 7 is a comparison table, so ask which tool a small team could run in a week: Ansible is the approachable answer. Slide 8 covers attack-surface reduction: services, ports, default accounts, least privilege. Slide 9 separates the three hardening layers, and the exam likes the firmware line, because secure boot refuses unauthorised firmware at start up. Slide 10 is the caution: a control that blocks a business process gets switched off quietly, so assess impact, test, document and review.

Slides 11–15 · Mobile and wireless (25 minutes)

Slide 12 lists the mobile risks and answers them with mobile device management: policy, configuration, compliance checks and remote wipe. Slide 13 compares BYOD, corporate owned, containerisation and application vetting; the trade is always control against freedom. Slide 14 runs the four wireless generations in order, WEP, WPA, WPA2, WPA3, and stresses that each exists because the last failed; WPA3 adds forward secrecy. Slide 15 separates pre-shared key from enterprise authentication, then covers rogue access point detection and the site survey as a security control rather than a coverage exercise.

Slide 16 · Break (10 minutes)

Ten minutes. On return the session moves to applications, assets and the vulnerability loop.

Slides 17–22 · Applications and monitoring (20 minutes)

Slide 18 is secure coding: least privilege, error handling, code review, input validation and boundary checking, with allow listing preferred over blocklisting. Slide 19 is the defence table: web application firewall, sandboxing, allow listing, code signing and runtime self-protection; ask where each earns its place. Use slide 20 for the discussion: an allow list prevents, a sandbox contains, code signing verifies, monitoring detects.

Slides 21 and 22 cover watching: authentication attempts, privilege usage, network traffic and system change, then the trade off between real-time alerting, trend analysis, scope, storage and alert fatigue.

Slides 23–28 · The asset lifecycle (15 minutes)

Slide 24 puts security in the purchase order: requirements, vendor assessment and supply chain verification, which defends against a malicious change during manufacture or delivery. Slide 25 draws the owner and custodian roles, and the inventory that answers what else touched the asset. Slide 26 makes tracking continuous: location, configuration, patch state, licences and unauthorised installs. Slide 27 is the disposal table, and the key distinction is that degaussing does nothing for flash memory. Slide 28 closes with chain of custody, verification and the regulatory duties.

Slides 29–36 · Vulnerability management (25 minutes)

The loop is the spine of this session and of the exam. Slide 30 covers network, host and application scanners, and the blind spot: no scanner finds a design flaw. Slide 31 contrasts credentialed and non-credentialed scans and stresses scope, because a scan that misses a critical database tells a comfortable lie. Slide 32 separates the CVSS metric groups: base never changes, temporal moves with exploit and fix availability, environmental makes it yours. Slide 33 adds the context that sets priority: criticality, exposure, exploitability and validating a suspected false positive. Run the slide 34 activity here, then cover remediation on slide 35 and validation, exceptions and reporting on slide 36, which also carries responsible disclosure and the rules of engagement that make a penetration test legal.

Slides 37–39 · Monitoring tooling (10 minutes)

Slide 38 is the tooling table: SIEM for correlation across sources, log management for collection, storage and retention, network traffic analysis for exfiltration and floods, and file integrity monitoring against a baseline. Slide 39 covers user and entity behaviour analytics, risk scoring, dashboard design and alert tuning, and ends on the cost of noise: an analyst drowning in alerts will miss the one that mattered.

Slides 40–43 · Quiz and close (25 minutes)

Run the quiz, review the low-scoring areas, walk the takeaways and assign the revision checklist. Preview Session 11: security operations, monitoring, incident response and forensics.

Activity (slide 34)

An internet facing service with a medium score and working exploit code in the wild → remediate now, because active exploitation outranks the number. An isolated test server with a critical score and no exploit → later in the queue. A finding that will not reproduce → validate before acting, and protect scarce effort. Debrief: exposure and exploitation beat the raw score.

Discussion prompt (slide 20)

Assume something malicious will arrive. An allow list prevents it running, a sandbox contains what does run, code signing verifies the binary, and monitoring catches what slips past all three. That is prevent, contain, verify, detect, in that order of intent.

Topic map: quiz tags and slide codes

The class quiz still tags each question with the session's original area codes. The slides now follow the book's subtopic codes, because the expanded narration reallocated several areas to other sessions. Use this table to reconcile the two when a candidate asks.

Quiz tag	Covers	Where it is taught now
10A Identification	Scanners, agents, CVE and asset context	Slides 30 to 31, plus the asset slides 24 to 26
10B Assessment	CVSS, prioritisation, false positives	Slides 32 to 33
10C Remediation	Patching, compensating controls, exceptions	Slides 35 to 36
10D Reporting & Disclosure	Reporting, responsible disclosure, rules of engagement	Slide 36
10E Resiliency	Recovery objectives, backups, redundancy	Session 7 (resiliency and backup strategy)
10F Site Security	Physical and environmental controls, disposal	Session 8 for site and environmental; slides 27 to 28 here for disposal

Common misconceptions and corrections

Misconception	Correction
"A baseline is a one-off project"	Implementation is four steps; holding the configuration there is continuous, because drift arrives through unauthorised changes and missed updates
"Two machines built the same stay the same"	Without a baseline and drift monitoring they diverge, and nobody can say what normal looks like
"More hardening is always better"	Over-hardening breaks operations, and a broken control gets switched off quietly. Test, document and review against operational need
"Secure boot is a firmware version check"	Secure boot refuses to load unauthorised firmware during start up
"A pre-shared key is fine at scale"	One passphrase shared by everybody means one leak opens the network; enterprise authentication sends each credential to a RADIUS server
"WPA3 is just WPA2 with a longer key"	It introduces the Simultaneous Authentication of Equals handshake, which resists offline guessing, and adds forward secrecy
"Blocklisting is as good as allow listing"	

Misconception	Correction
	The bad list is never finished; allow listing names what is permitted and refuses the rest
"A sandbox removes the risk"	A sandbox contains what runs so a compromise stays in one room; it does not make the code safe
"CVSS score equals risk"	Score is severity; risk adds criticality, exposure and exploitability
"Non-credentialed scans see everything"	Credentialed scans reveal internal state such as missing patches and misconfiguration
"Degaussing wipes any drive"	A magnetic field erases magnetic media and does nothing for flash storage
"Disposal ends at destruction"	Verification and chain of custody records are the evidence of compliance
"A scanner finds every weakness"	Scanners find known weaknesses on known systems; none of them finds a design flaw
"Scope only affects how long a scan takes"	A missed critical asset is a false comfort, and a wider scope sets your storage bill and detection ceiling
"More alerts means better detection"	Alert fatigue hides the alert that mattered; thresholds and rules need tuning

Assessment check

- Slide 3 outcomes map to the twelve book subtopics and the six narration chapters.
- The HTML quiz tags every question with its session area for traceable revision; the topic map above reconciles those tags with the slide codes.
- The Wayground quiz (15 questions) gives an in-class, importable assessment of the same topics.
- Ask candidates to produce one baseline setting, one compensating control with a review date, and one disposal method with its verification step.